



Design of blockchain-based authentication and key agreement protocol for health data sharing in cooperative hospital network

Divya Rani¹ · Sachin Tripathi¹

Accepted: 3 August 2023 / Published online: 18 August 2023

© The Author(s), under exclusive licence to Springer Science+Business Media, LLC, part of Springer Nature 2023

Abstract

Health data collected from IoT devices can be utilised for predicting various medical information. The information collected is stored in centralised server and can be shared among various branches of the cooperative hospital network for analysis purposes. However, these communications are wireless which leads to various security threats like unauthorized access by intruders and misuse of health data. The existing work provides an authentication scheme that depends on trusted third party and centralised storage. This increases the computational burden and latency at the centralised server and may lead to a single-point failure. To solve this issue, a Blockchain-based authentication and key agreement scheme is proposed for sharing health data. The proposed scheme incorporates the concept of Blockchain that makes the system distributed, immutable, and transparent. An Elliptic Curve Cryptography based authentication scheme is proposed where all the information is stored in the Blockchain. In addition, a secret key is established to provide secure communication among patients, Hospital servers, and IoT devices. Hyperledger Fabric platform is used for Blockchain implementation that supports channel communication. There is a formal analysis using the ROR model that proves the security of the session key. The formal simulation using the Scyther tool shows that there is no attack within bound. Moreover, the informal analysis proves that the proposed work is resistant to various attacks and satisfies the security goals. The comparative study demonstrates that the proposed work is more effective as compared to others. The proposed work involves implementing a system of cooperative hospital servers that communicate through a shared channel. Hospital servers belonging to the same channel will be able to communicate securely and privately. This setup also facilitates the efficient transfer of health data among various hospital servers, eliminating the need for redundant computations during registration and authentication processes on each server. Additionally, the use of Blockchain reduces dependency on third party, makes the system distributed, provides immutable storage and increases confidentiality among members by using channel communication.

Extended author information available on the last page of the article

Keywords Authentication · Key agreement · Consortium blockchain · Hyperledger fabric · ECC · IoT devices

1 Introduction

Nowadays, the management of health data is an important concern. It should be shared between users like doctors or patients and hospitals in the form of a digital record to analyse it for disease prediction based on the symptoms. It can also be shared between different hospitals to reuse it for a patient's past medical history. This requires a secure way of data transmission between two entities that increases users' trust in digital medical records.

This Covid-19 Pandemic increases the need of sharing health data to decrease operational cost as there is no need to deal with several branches of a hospital separately if the patient's health data are shared among all the branches in a cooperative hospital network autonomously. The coordination among various hospital branches increases as health data shared automatically to all hospitals in a cooperative network irrespective of the place of treatment. The secure transmission of health data by authentic device or user guarantees fast service and also prevent repetition of various activities at all other branch of the hospital. Various regulatory acts are passed by different government for health data protection like Data Protection Bill, 2021 passed by the Indian Government where health data is defined as sensitive personal data, the Health Insurance Portability and Accountability Act (HIPAA) passed by the US department of Health and Human Service (HSS) provides standard to protect patient's health data. Therefore, security of health data transmission is important.

Confidentiality and Privacy of Patient's personal information is the main area of focus. The hospital server stores this information and exchange it for various purpose. However, this process of storage is vulnerable to various cyber-attacks, data manipulation and misuse of information by attackers. Patients may lack trust in the Hospital if their information is leaked or misused by any means. So, there is a need to build trust by incorporating an immutable storage system. This medical information can be used for various research analyses like disease prediction, early detection and so on. The exchange of medical data can be attacked and misused by intruders. The attacks that are very common like Phishing attacks and ransomware attacks are threats to maintain the privacy of personal information. In order to protect this, information should be shared among trusted members only and channels of communication should be completely secure. Moreover, authentication of users and devices is very important for secure communications. The proposed work incorporates the Blockchain concept for immutable storage to maintain data privacy, ensures confidentiality among members and provides secure channel communication.

In recent years, the use of IoT devices modifies the way of treatment followed by the doctor which simplifies access to health care data. Various IoT devices or Internet of Medical Things (IoMT) are used in the hospital like Smart Bed, Smart Lab, Ultrasound and so on that are used to collect patient's health data. While transferring health data with the Hospital, there is a need to verify the authenticity of the IoT device and the user with whom data is to be shared. For instance, IoT-based diabetes

monitoring devices where patients' glucose levels are monitored using wearable sensors. The information collected is sent directly to the reader through an application on the smartphone. Sometimes, these IoT devices are left unattended and can be changed or manipulated by attackers. So, there is a need of checking the authenticity of the devices before transferring health data to the Hospital Server.

In order to authenticate IoT devices and user like doctor or patient, Blockchain-based authentication scheme using Elliptic Curve Cryptography (ECC) algorithm is proposed. Consortium Blockchain is used which is a permissioned blockchain where multiple organisations are involved. The communication between these parties is through the channel where the members of that particular channel can communicate privately. This leads to confidentiality of data exchanged between the members. For implementing Hospital Consortium, Hyperledger Fabric is used because of its distinguishing features. It provides confidentiality of transaction. In this, members can communicate privately using channel. Since it is a permissioned blockchain, each organisation is provided with unique identity by its Certification Authority (CA). Unlike Public Blockchain, the members are known to each other. Also, it is programmable that supports Smart Contract where various rules are defined. Also, there is no need of cryptocurrency. Because of the immutable and irreversible features in Blockchain, it is used to store data related with registration of user and IoT device. In the proposed work, Hospital Server is a member of Hospital Consortium and stores registration related information. There are other members like Admin, Pharmacy, Reception, and so on that act as Peer Node.

1.1 Motivation

In a traditional system, the centralised server is used by the hospital to store health-related records of the patient. Each hospital has its own server and information sharing is very difficult between the hospital. Many researchers use centralised systems for storing electronic health records. Most of them used cloud servers for data storage as data can be accessed through online mode in cloud computing. Hathaliya et al. [12] proposed an authentication scheme using biometrics for securing information. However, the main limitation of this work is that it uses a cloud server and Electronic Health Record (EHR) for storing patient records. The authentication scheme proposed by Anuradha et al. [5] and Jiang et al. [15] also uses the cloud computing concept. Fan et al. [10] proposed an authentication scheme using cloud computing in the RFID health care system. Cloud-based authentication scheme faces a centralised problem and there is a chance of insider attack in centralised database. This should be replaced by decentralised structure. The proposed work involves a Blockchain based decentralised structure to remove the problem of cloud computing.

There are many factors that can be used for providing authentication schemes like passwords, identity, biometrics, and smart card. Some researcher has used two-factor authentication schemes where they used identity and password as two factors. Wang et al. [36] proposed an authentication scheme using two-factor and cloud computing. However, most of the security goals are not achieved using two

factors. In order to enhance security, biometrics is used as the third factor in the proposed work. Because it cannot be tampered with and are different for a different person.

Most of the cryptographic techniques used for the authentication scheme are not ECC based. Dharminder et al. [8] use the RSA algorithm for designing an authentication scheme to secure health care services. However, ECC is more efficient than other non-ECC-based mechanisms as it uses less key size and also takes less time in key generation. The security level provided by 160 bits key in ECC is equivalent to the security level provided by 1024 bits in RSA. Thus, ECC-based algorithms have low computational costs as compared to non-ECC-based algorithms. The proposed work uses the concept of ECC point multiplication and point addition for designing an authentication scheme.

There is a need to protect the registration related information so that it cannot be accessed by the unauthorised parties. Blockchain is a distributed, decentralised structure that store data in a chain of block and is immutable and irreversible. If the storage of registration-related information is inside the blockchain, it will be highly secure. Therefore, the proposed work stores all the registration-related information in the blockchain. There is a requirement for Remote Medical Information sharing system in order to collect data from IoT Devices and store it in such a way that it can be reutilised. A single server system requires the reauthentication of the patient and IoT devices at every hospital. If the work involves multiple branches of the hospital connected by the channel for storing information, then this information from one server can be accessed by the other by establishing communication using the channel. In order to use the service of IoT devices, both the patient and IoT device need to authenticate themselves with Hospital Server. For secure data transmission between IoT devices and Hospital servers, there is ECC-based key exchange mechanism.

1.2 Contributions

The contributions of this paper are mentioned below:

- A model is designed for secure health data sharing in a cooperative hospital network that uses the Blockchain concept for authentication purposes. This makes the system distributed, and immutable and increases the transparency of the transaction.
- All the registration-related information is stored in the Hospital Server that is a part of the blockchain so that it is immutable and highly secure.
- The hospital can communicate with each other using a dedicated channel.
- There is authentication of IoT devices and users like patients or doctors with the hospital server and generation of Session Key for communication between the participants using ECC protocol.
- The blockchain operation is implemented using the Hyperledger Fabric platform that makes the system permissioned, transparent, removal of cryptotoken, and programmable.

- There is a formal and informal analysis of the proposed protocol. The formal analysis and simulation is performed using the ROR model and Scyther tool, respectively.

The remaining paper construction is as follows: In Sect. 2 related work is discussed. Then the preliminary concept used in the proposed work like Blockchain, Consensus mechanism, three factor authentication, Elliptic Curve Cryptography, and security goal is explained in Sect. 3. Section 4 explains the architecture, initial assumptions made for cryptographic protocol, registration phase of IoT device and User (Patient or Doctor), mutual authentication, and key agreement scheme. There is formal security analysis using the ROR model, simulation of the protocol using Scyther, and informal analysis discussed in Sect. 5. In Sect. 6, the process of blockchain implementation and various cost analyses is discussed. Section 7 explain the comparative cost analysis of various work using the ECC algorithm for mutual authentication and key agreement. Thereafter, Sect. 8 discussed the conclusion of the proposed work.

2 Literature survey

The Internet of Things(IoT) plays an important role in making the system smart and more efficient. There are a lot of IoT based applications that make the system more efficient like Smart Agriculture, Smart Hospitals, Smart Vehicular Systems and so on. However, it is vulnerable to various attacks while transferring data from IoT devices and so, there is a need to focus on various privacy and security concerns. Saleh et al. [2] focuses on data integrity and authenticity and proposed an authentication scheme for Smart Agriculture. Asima et al. [27, 28] proposed an anomaly detection system for IoT networks. Waseem et al. [17] designed a framework for cyber security in IoT-based logistic containers. This shows that there is a need to focus more on the security concern of IoT-based applications.

Authentication is one of the important security services that can be used to verify and identify the identity of any entity or user. Various protocols are proposed for mutual authentication and key agreement in the IoT environment which is analysed in this section and shown in Table 1. Health related data stored in Hospital Server can be shared with patients, doctors, and other hospitals for various analysis purposes. There is a need to authenticate patients, doctors, Staff, and devices before sharing health data to prevent unauthorized access. Many researchers proposed mutual authentication and key agreement protocol. Tanveer et al. [35] proposed an authentication scheme for medical information systems of health data generated in an IoT environment. The health data generated by the IoT devices are shared through the public channel and is vulnerable to various attack. Therefore, this requires a proper authentication scheme. The authentication scheme given by Madhusudhan et al. [21] is for medical information systems where the privacy of patients and authorized access to the medical server is focused. Mukesh Soni et al. [30] proposed an authentication scheme for ensuring the privacy of the patient and a key exchange mechanism for secure communication between the medical server and the patient.

Table 1 Related work

Refer- ence	Published Year	Approach	Advantage	Disadvantage
[30]	2022	– Authentication and key exchange Protocol using ASCON	– Maintains the data integrity, confidentiality and authentication – secure session key – resistant to various security attacks	– Medical Server is too powerful – MS stores all sensitive information – No distributed Storage – No concept of channel communication and multi-server
[7]	2020	– RSA based 2 factor authentication scheme – Uses SHA and XOR operation	– Provides dynamic identity to provide anonymity – secure session key between user and server – resistant to various attack – Uses biometric as a factor making it more secure	– Storing information in single server – Larger key size as compared to ECC based protocol – takes more time for key generation in comparison to ECC – No distributed storage – No concept of channel communication and multi-server
[25]	2023	– ECC based 3 factor authentication Protocol	– Faster key generation with smaller key size – Provides same level of security with smaller Key size – In comparison with non-ECC based protocol – Resistant to various security attack	– Information stored in gateway and sensor node – This increases dependency on it making it vulnerable To attack – No distributed Storage – No concept of channel communication and multi-Server
[14]	2020	– 3 factor authentication using Cloud Computing	– Uses biometric as a factor that cannot be Altered or stolen – Secure remote access of information stored In cloud	– Centralised way of data retrieval – Store information in one centralised location – Possibility of single point failure and various attack – Data can be mutable – Doesnot assure complete tamper-free data – Chance of insider attack
[33]	2022	– Blockchain based encryption Scheme	– Distributed and decentralised structure because Of blockchain – Immutable data storage	– Uses permissionless blockchain concept – Public Blockchain Ethereum is used – No confidential communication among users as there Is no concept of channel – Uses cryptocurrency

This shows that authentication and key agreement are required in order to prevent unauthorized access and to provide secure communication between various entities involved in the IoT environment.

Authentication protocol can be designed by using several factors. Various two factor authentication scheme was proposed where identity and password are used as the factor. However, three factor authentication scheme provides a more secure protocol in an IoT environment. Many researchers have proposed three factor authentication scheme where they use identity, password, biometrics, and smart card as factors. These factors are something that is known (password or identity) or the thing that a person have like a smart card or the thing that can be inherent like biometrics. Jiang et al. [15] proposed an authentication scheme using three factors- a password, a biometric, and a smart card that ensure secure access to autonomous vehicles and the cloud. The authentication scheme given by Hathaliya et al. [12] includes biometrics as a factor for authentication purposes. As Biometric input cannot be copied or altered or stolen from others, it can be used as one of the secure factors for authentication. Hamidi et al. [11] proposed an authentication scheme for smart health where they have used biometrics as an identifier or factor. Chin-Laung et al. [19] proposed an authentication scheme having biometrics as one of the secure factors. This study shows that including biometrics as a third factor along with password and identity enhances the privacy and security of the protocol.

Various traditional cryptographic scheme is proposed for mutual authentication and key agreement in an IoT environment for the secure transmission of health data. Rehman et al. [24] proposed a lightweight authentication scheme using hash and XOR operation for securing patient's health-related data. The authentication scheme proposed by Mehedi Masud et al. [22] comprised hash and XOR operations for securing health data generated by IoT devices. However, Elliptic Curve Cryptography (ECC) is preferred by many researchers because of its fast key generation and smaller key size. ECC-based protocol takes less computational time as compared to non-ECC based protocol. Sowjanya et al. [31] proposed an authentication scheme based on the ECC algorithm for secure health data generated from the Internet of Medical Things (IoMT). The authentication scheme proposed by Servati et al. [29] used the ECC algorithm for designing protocol in order to prevent unauthorized access to health-related data. Sadhukhan et al. [25] proposed an ECC based protocol in order to preserve data privacy for secure communication between various IoT devices. Moreover, the security provided by the ECC is greater than the non-ECC based algorithm. This shows the benefit of using ECC for designing authentication protocols.

However, this security level can be enhanced by using the blockchain concept for authentication purposes. Blockchain makes the system robust and decentralised. The main features of blockchain are the data transparency between the members and the integrity of data without involving a third party for verification purposes. Moreover, the information stored in the blockchain is immutable and so, cannot be tampered with or stolen by attackers. Cheng et al. [7] proposed an authentication scheme based on blockchain for sharing medical data. The permissioned blockchain is suitable for business applications where one or more parties are involved and communication takes place between these parties only. Most of the application requires their

information to be confidential and known only to the involved parties between which the transaction takes place. Xiang et al. [39] proposed an authentication scheme that involves permissioned blockchain for authentication purposes. A consortium blockchain is designed where more than one party is involved and the transaction takes place between these parties. This is very important when the communication between the members occurs privately by using the channel. A separate channel is created between the parties between which the transaction has to be executed. The authentication scheme proposed by Tang et al. [34] used the concept of Consortium Blockchain for maintaining the security of Electronic Health Records. Based on this study, the proposed model uses Consortium Blockchain for designing ECC based authentication scheme.

The existing work related to authentication mostly relies on the centralised server and trusted third party. There is some work that used cloud computing for storage purposes which involves centralised way of data retrieval. Some researchers utilize public Blockchain networks that are permissionless and require cryptocurrency. Additionally, some projects based on Blockchain technology lack the incorporation of multiple servers and the concept of channels. To solve this issue, Blockchain-based authentication and key agreement scheme is proposed. The authentication protocol is designed using ECC protocol and the session key is designed for secure communication. The registration-related information is stored in Blockchain which makes the system decentralised and immutable. There are multiple servers that communicate using channels. This decreases computational overload at a single server by removing redundant registration at each server. The members belonging to the same channel can communicate securely and privately which ensures confidentiality.

3 Preliminaries

This section discussed various concepts used in the proposed work like blockchain, consensus mechanism, ECC protocol, three factor authentication, and security goals.

3.1 Blockchain

Blockchain is a decentralised data structure that is shared among multiple parties in a decentralised peer-to-peer network. This can be used in various distributed IoT applications [32]. The set of transactions is stored together in a group within a structure called Block where each block is interconnected with the hash of the previous block. This lead to the formation of a chain of data called Blockchain. The basic difference between a database and a blockchain is that the database store data in the form of a Table where as the Blockchain stores the data in the form of a Block that form chain-like structure. Each block consists of information like the hash of the previous block, the timestamp of the block when it is added to the existing chain, and a set of transactions. The entries inside the block are irreversible and immutable. Once edited, it cannot be altered. So, it is also called Distributed Ledger Technology (DLT). In this structure, each node maintains its copy of the chain information

that gets updated whenever any change occurs. For any change, this copy has to be updated by all the added nodes. This provides transparency among the added nodes. The first block is called Genesis Block. Because of these features, Blockchain can be used to store sensitive information in order to enhance the security of the existing model.

3.1.1 Blockchain Types

Various types of Blockchain [23] based on the access control are described below-

- *Public Blockchain* This is a Permissionless Blockchain as anyone having the internet can join the chain and become a member to access the information added to the blockchain. Each node participates in the consensus mechanism to execute or validate any transaction. So, 'Proof-of-work' is used as a consensus mechanism. Various examples of Public Blockchains are Ethereum [38], Bitcoin.
- *Private Blockchain* This is a Permissioned Blockchain as there is a restriction in its uses. It involves a single party and is managed by a network administrator. It is maintained by a private organisation that can control the mining process and the consensus mechanism. Various examples are Corda, R3(Banks), EWF(energy) etc.
- *Consortium Blockchain* This is also a Permissioned blockchain that is owned by a private firm but involves multiple parties. More than one organisation is involved to form the chain [9]. Communication between various parties takes place by using the channel. No transaction fees are required. Hyperledger Fabric is used to implement Consortium Blockchain [1, 4].

3.1.2 Blockchain Implementation

Hyperledger Fabric is a Distributed Ledger Technology that is used in the proposed model. The main feature of Hyperledger that makes it more efficient are maintaining confidentiality among transaction, no use of cryptocurrency, permissioned blockchain, and programmable feature. Transactions are initiated by the node that executes chaincode and these transactions are recorded in the ledger following the received sequence of order. It constitutes various types of the node-

- *Orderer Node* This node is responsible for providing an ordering service where the sequence of the transaction is decided. Consensus Mechanism is implemented by the Orderer Node.
- *Peer Node* All the other nodes that maintain their copy of the ledger are called Peer Nodes. This node maintains the log of the transaction, state database, and chaincode. Anchor Peer is a node that is known outside the organisation. Each organisation has one Anchor Peer.
- *Client Node* This is like the end user node that sends a transaction request to the network.

3.2 Consensus mechanism

Hyperledger Fabric is a Distributed Ledger Technology (DLT) for designing Consortium Blockchains and is very important for implementing business related applications where two or multiple organisations are involved. As it is a distributed ledger, each participating node has its database that is updated independently. The transactions are communicated to multiple nodes. So, each node follows some mechanism that will decide the sequence of transactions. This sequence for any operation is fixed and must have the same order. The process is called Consensus Mechanism [18]. Permissionless or Public Blockchain uses 'Proof-of-work' as a consensus mechanism that is based on the Probabilistic approach. This is because every transaction is visible to every node and so, there is no confidentiality maintained. Permissioned Private or Consortium Blockchain uses no consensus or Practical Byzantine Fault Tolerance (PBFT). In Hyperledger Fabric, this is implemented by the Orderer Node and uses a deterministic approach. As there are 'n' number of orderer nodes, there is a need for consensus. Hyperledger Fabric provides confidentiality and privacy for a transaction that is maintained using the channel. Only the member having a common channel has access to a particular set of transactions. Moreover, it has a pluggable consensus that can be updated based on the requirement. Various ordering services in Hyperledger Fabric are described [37].

- **Solo** Solo ordering service involves a single instance of the ordering node and cannot be used in the form of a cluster. This lead to a single point of failure as the consensus depends on a single orderer node only. So, this consensus mechanism is used only for test purposes.
- **Kafka** This ordering service involves multiple instances of the ordering node and can be used in the form of a cluster. So, there is no single point of failure, and provides Crash Fault Tolerance (CFT). If one orderer node does not work, the other available orderer node participates in the consensus mechanism. The model is based on the '*Leader and Follower*' concept where the main decision is taken by the Leader and the Follower has to agree on that decision.
- **Raft** This ordering service also involves multiple instances of Orderer Node, supports cluster, and provides CFT. This is also based on '*Leader and Follower*' concept. However, there are several advantages of Raft over Kafka-
 - In Kafka, multiple orderer nodes are involved but there is a need for one organisation that can control the Kafka cluster. It means that Kafka is not completely decentralised. However, In Raft, each organisation has its ordering node participating in ordering service independently making it completely decentralised.
 - Raft can be easily implemented as there is no need to design a Kafka cluster maintained by an organisation.
 - Kafka has its design that should be coordinated with the designed Orderer Node. But in a raft, there is no separate design, and can be implemented directly into the designed orderer node.

- Kafka requires brokers and zookeepers to decide the number of nodes in a particular channel whereas, In Raft, users decide which orderer node belongs to which channel. In the proposed work, the Raft consensus mechanism is used.

3.3 ECC-based authentication and key agreement

Mutual Authentication is the process of authentication of one entity with the other and vice-versa. The proposed model includes data transfer from the IoT device used in the hospital to the Hospital Server and then transfers this health data to the user-Patient or Doctor. This requires Mutual Authentication between the IoT device and Hospital Server and between Hospital Server and the Patient or Doctor. Also, for the secure transmission of health data from IoT devices to the Hospital Server and from Hospital Server to Doctor or Patient, there is a need for a session key. Therefore, a common session key is generated by the entities to exchange health data after successful Mutual Authentication. For this process, Elliptic Curve Cryptography (ECC) algorithm is used.

3.3.1 ECC Algorithm

ECC is a public key or asymmetric cryptographic technique that uses an elliptic curve defined by some mathematical function of degree 3 over a finite field [29]. It is given by-

$$y^2 = x^3 + mx + n \quad (1)$$

This curve is symmetric to the x-axis. ECC algorithm can be used for the key exchange agreement process by using the Generator Point. As compared to non-ECC algorithms like RSA(Rivest Shamir Adleman), ECC provides an equal level of security using a smaller key size. For instance, 160 bit key size in ECC provides the same level of security as compared to 1024 bit key size in RSA.

3.3.2 Terms used in Algorithm

- $E_p(m, n)$ - This denotes the Elliptic Curve over a finite field having p, m, n parameters where 'p' is a prime number or in the form of 2^a .
- *Generator Point 'G'*- This is also called Base Point which is a point on the elliptic curve having order equivalent to the large value of the limit point. This can generate other points on the Elliptic Curve by multiplying itself(G) with some integer in the range [0.....k].
- *ECC Point Multiplication*-If the Generator Point G is multiplied by any integer like n_1 , corresponding public key P is generated. It can be represented by $P = n_1 \cdot G$ where n_1 is considered as a private key integer and P is considered as a Public key Point.
- *ECC Point Addition*- Any line drawn over the Elliptic Curve crosses a maximum of three points. Let, A, B, and C denote these points. When it touches the Elliptic

Curve at three points having different x co-ordinates then it forms ECC point addition and is given by $A + B = C$ where C is the point on the Elliptic Curve that is equivalent to the negation of the third point where the Elliptic Curve and Straight Line intersect.

3.4 Three factor authentication

The proposed model uses three factors for Authentication Process- User's Identity, Password, and Biometrics. By using these three factors, Mutual Authentication and Key Agreement protocol is designed. The user's Biometric Data is recorded and it has to be converted into the key. Fuzzy Extractor is used to generate the key of length 'l' bits from the user's biometric input based on the Error Correction Method. Biometric input is denoted by P_{Bio} . Two functions are used-

- $Gen(P_{Bio})$ This function will take P_{Bio} as input and results in the generation of 'l' bits biometric key denoted by P_σ where $P_\sigma \in (0, 1)^l$ and helper data for reproduction denoted by P_τ .
- $Rep(P_{Bio})$ It takes P_{Bio}^* and P_τ as input where hamming distance $dis(P_{Bio}, P_{Bio}^*) \leq e$. 'e' is the threshold value for error tolerance. This will result in the generation of original 'l' bits biometric key, $P_\sigma = Rep(P_{Bio}^*, P_\tau)$

3.5 Security requirements

This section mentioned the security goal that needs to be fulfilled.

1. *Reduce third party dependency*: There is a use of blockchain concept in the proposed work. Blockchain is a decentralised and distributed structure where there is no need for a trusted third party or any centralised authority to verify the process. As each node or member of the blockchain maintains the sequence of the transaction, it is easy to find out any tampered things.
2. *Confidentiality of transaction*: The proposed work uses Consortium Blockchain that is permissioned where identities and rules are assigned. As most applications need confidentiality of information that could be shared only with its authentic members, Consortium Blockchain. It uses Hyperledger Fabric for implementation where members can transact privately using a channel. This ensures the confidentiality of information.
3. *Data privacy*: All the data related to the registration of patients or doctors or IoT devices is stored in the blockchain which is known for its immutability features. Moreover, the branches of a hospital can access health data of each other by using a channel for communication. The data can be shared if the branch of the hospital is using a common channel for communication purposes. In this way, the privacy of data is preserved.
4. *Mutual authentication*: IoT devices can be malicious or tampered and so, there is a need to register all the IoT devices used in the hospital. Users like doctors or patients also need to register with the hospital server. For secure transmission of

health data from an IoT device to a Hospital Server and from Hospital Server to User like a doctor or patient, there is a blockchain based mutual authentication and key agreement using ECC protocol.

5. *Security of session key*: Session Key is designed for secure communication between IoT devices and Hospital Server, between Hospital Server and User like doctor or patient. This session key is designed using ECC point multiplication and point addition. As it involves the use of basepoint and random numbers, it is difficult to guess it in polynomial time. So, the proposed work ensures session key security.
6. *Prevent various security attacks*: The proposed work prevents various security attacks like Man in the Middle attack, replay attacks, impersonation attacks, and known session key attacks. This increases the security of the proposed protocol of mutual authentication and key agreement.

4 Proposed model

This section explains the proposed architecture of a cooperative hospital network, a table consisting of all cryptographic assumptions, and the protocol for the secure transfer of health data generated from IoT devices.

4.1 Proposed architecture of the system

The proposed system uses the concept of Consortium Blockchain. Various entities involved in the model are described below-

1. *Doctor*: The doctor registers with the cooperative hospital network before treating the particular patient to prevent unauthorised access. Their information is stored in the node of the blockchain.
2. *Patient*: Patient register with any branch of the cooperative hospital network. There is mutual authentication and key agreement between the Patient and the Hospital Server to provide the generated health data from Hospital Server to the Patient.
3. *IoT Device*: These devices register with the Hospital and can be used to generate health data of the patient. For transferring the health data to the Hospital Server, there is mutual authentication and key agreement between IoT Device and Hospital Server.
4. *Hospital Server*: Hospital Server is designed as a node of the blockchain that can store all the information related to the registration of Patients and IoT Devices.

In the proposed system model, the first step is the registration of IoT devices. Doctors need to register with the hospital and are added as a client of the distributed ledger. Patient registration with the hospital and all the information related to the registration is stored in a hospital server that acts as a node of the blockchain. Then, the hospital assigns a doctor to the patient. The patient consults with that doctor for

treatment. Various health data are generated by the IoT device of the Hospital which is transferred to the Hospital Server so that it can be used for further analysis. The patient may request their health data and get it through the Hospital Server. They may visit the other branch of the hospital for treatment purposes. As all the branches of the hospital a part of the distributed ledger and can communicate with each other using channels, the patient's information, and health data can be shared among each other. This process is shown in Fig. 1.

4.2 Initial cryptographic assumption

There are three participants involved in the proposed protocol for mutual authentication and key agreement- Users can be a doctor or Patients, Hospital servers, and IoT Device. The first step is the registration of IoT devices used in the hospital to prevent unauthorised access. Then, the users (doctors or patients) register with the Hospital Server and become an authentic members. All the registration related information is stored on the Hospital Server. Patient health data generated from the IoT devices need to be transferred to Hospital Server. Users can access this health data through

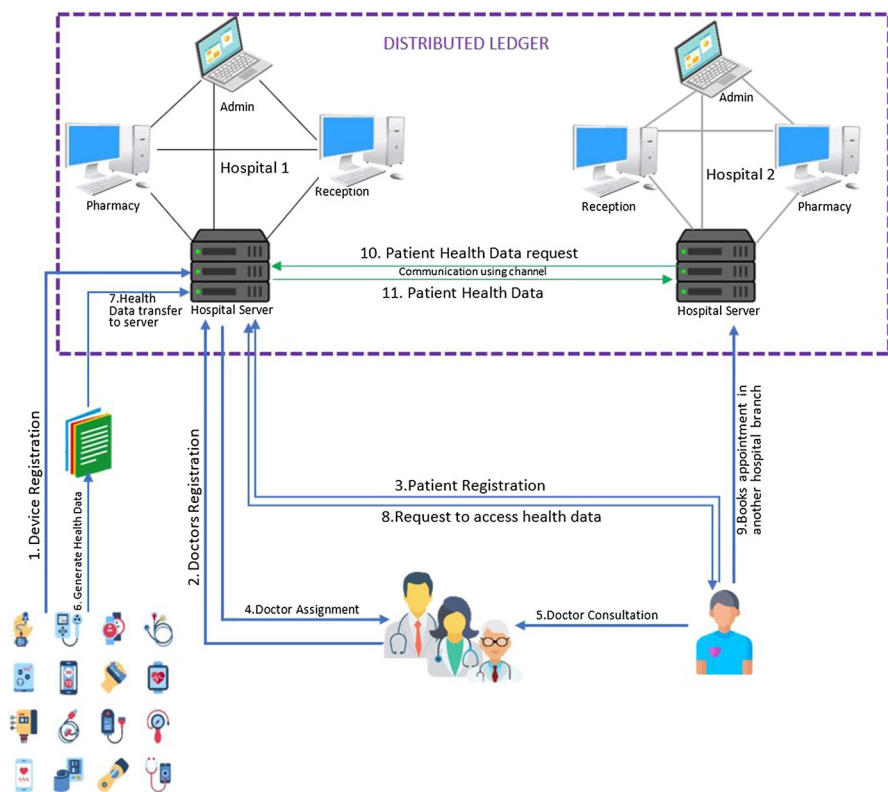


Fig. 1 Proposed system model

Hospital Server. So, there is a session key agreement between these three entities for secure data transmission using the public channel. Various symbols used in the protocol are mentioned in Table 2.

4.3 Registration phase

There are three participants involved- The user (Doctor or Patient), Hospital Server, and IoT Device. This phase includes user and device registration. The registration related information is stored in the blockchain.

4.3.1 User registration phase

Patients or doctors need to register with the Hospital Server in order to access the health data stored in the Hospital Server as shown in Fig. 2. There are three factors used for the process of registration and authentication- Identity, Password, and Biometrics. Hospital Server is a node of the blockchain and stores registration related information making it secure and immutable.

- Patient enters its unique identity P_{ID} , corresponding password P_W and its biometric P_{Bio} . The generator function is used to extract σ bits biometric key.

Table 2 Symbols with their abbreviations

Symbol	Meaning
P_{ID}, P_{TID}	Unique identity, temporary& identity of the Patient
D_{ID}, D_{TID}, D_{NID}	Identity, temporary and new identity of the Device
P_W, P_{TPW}, P_{NPW}	Password, temporary and new password of the Patient
$P_{Bio}, P_{\sigma}, P_{\tau}$	Biometric input of the patient
R_p, R_D, R_{HS}	Random number generated by Patient, Device and Hospital Server respectively
PrK_{HS}, PuK_{HS}	Private and public Key of the Hospital server
$P_{ID}^*, P_W^*, P_{NPW}^*, P_{Bio}^*$	Received identity, password, new password & biometric of the Patient
n_1, n_2, n_3	Random variable used for ECC by the Patient, Hospital Server & IoT Device respectively
P	Basepoint used for ECC protocol
$TS_1, TS_2, TS_3, TS_4, TS_5$	Timestamp recorded at particular instance
ΔT	Upper time limit of the message transmission delay
NO_{SD}, NO_{HS}	Nonce generated by the IoT Device & the Hospital Server respectively
$S_{Key_D}, S_{Key_P}, S_{Key_HS}$	Session key derived by the IoT device the Hospital server & the Patient

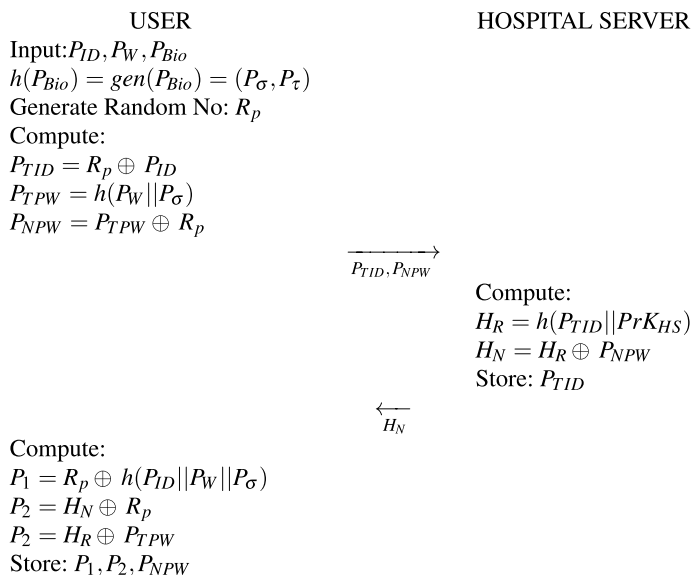


Fig. 2 User registration phase

- Random number R_p is generated and then temporary identity P_{TID} , temporary P_{TPW} and new password P_{NPW} is computed. Patient sends temporary identity P_{TID} and new password P_{NPW} to the Hospital Server through secure channel
- Hospital Server computes $H_R = h(P_{TID} || PrK_{HS})$, $H_N = H_R \oplus P_{NPW}$ using the message received from the patient and stores temporary identity P_{TID} . Then, it sends H_N to the patient through a secure channel.
- Patient computes $P_1 = R_p \oplus h(P_{ID} || P_W || P_\sigma)$, $P_2 = H_N \oplus R_p = H_R \oplus P_{TPW}$ using the message received from the hospital server and stores P_1, P_2, P_{NPW} .

4.3.2 IoT device registration phase

Various IoT devices are used in the hospital for collecting patient health data. There might be a possibility that unauthorized devices are placed in the hospital and are used for misusing patient information. There should be the registration of IoT devices used in the hospital in order to prevent unauthorized access as shown in Fig. 3.

- IoT device input its identity denoted by D_{ID} and generate a random number R_D . These are sent to the Hospital Server through a secure channel.
- Hospital Server generates a random number denoted by R_{HS} and computes $H_1 = (D_{ID} \oplus R_{HS}) \oplus R_D$, $D_{NID} = R_{HS} \oplus D_{ID}$. It stores R_{HS}, D_{NID}, D_{ID} for future use and sends H_1 to the IoT device.
- Once H_1 is received by the IoT device, it calculates $R_{HS}^* = (H_1 \oplus R_D) \oplus D_{ID}$ and $D_{NID} = R_{HS}^* \oplus D_{ID}$. It stores R_D, R_{HS}^*, D_{NID} for mutual authentication and key agreement process.

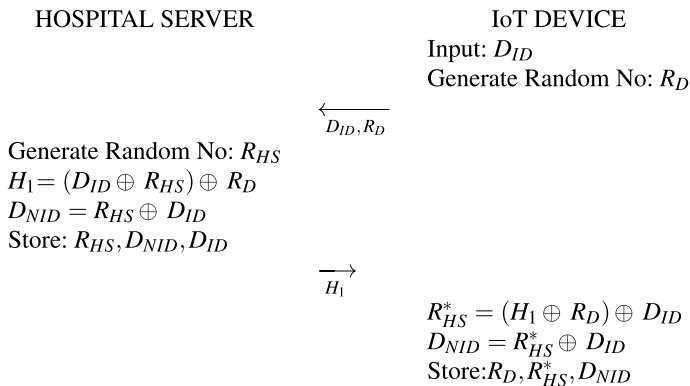


Fig. 3 IoT device registration phase

4.4 Mutual authentication and key agreement

There are many IoT devices embedded in the hospital that may be vulnerable to various security attacks while transferring health data to the Hospital Server. So, there should be mutual authentication and key agreement between IoT devices and Hospital servers for securely transferring data. Patients or Doctors also need these health data for treatment purposes. Mutual authentication and key agreement are required between the patient or doctor and the hospital server for the secure transmission of health data. Registration related information is stored in the local database of the blockchain. This process of Mutual Authentication and Key Agreement is illustrated in Fig. 4.

1. The authentication process begins with the communication between the User (Patient or Doctor) and Hospital Server.
 - Patient enters $P_{ID}^*, P_W^*, P_{Bio}^*$ and then repeater function is used to extract P_σ^* .
 - Then, it calculates R_P^* by using stored P_1 and $P_{ID}^*, P_W^*, P_\sigma^*$. P_{TPW}^* is calculated using P_W^* and P_σ^* . By using R_P^* and P_{TPW}^* , it calculates P_{NPW}^* . If the calculated value of P_{NPW}^* is equivalent to the stored P_{NPW} , then the process is continued otherwise, it will be terminated.
 - After that, random number n_1 is generated and timestamp TS_1 is recorded.
 - Further, ECC point multiplication is used to calculate S_1 and S_2 . Then, it computes P_{TID}^*, H_R^* and P_{NID} .
 - By using all this, it computes $x = h(P_{NID} || TS_1 || S_1 || S_2 || H_R^*)$ and sends P_{NID}, x, TS_1 to the Hospital Server.
2. Hospital Server receives a message from the user and checks the gap in timestamp by using $|TS_1^* - TS_1|$ that should be $\leq \Delta T$. If the gap is less than the threshold value, then it continues the further process otherwise the process will be terminated.

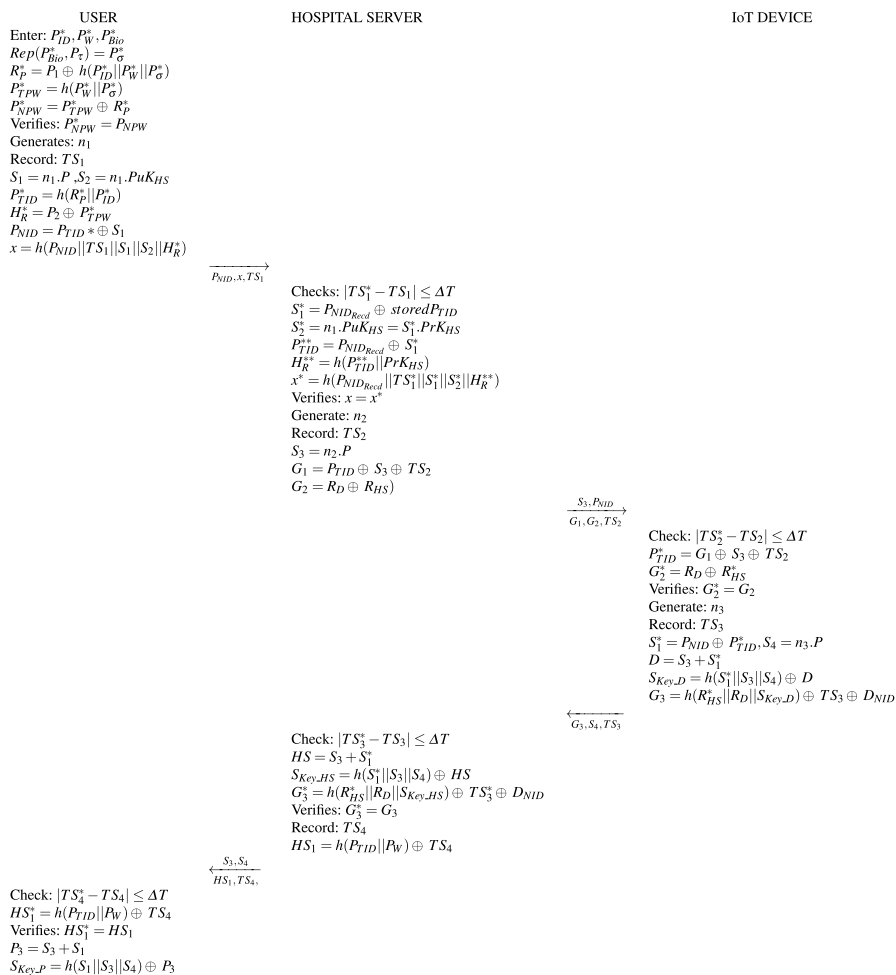


Fig. 4 Mutual authentication and key agreement phase

- By using received P_{NID} and stored P_{TID} , it computes S_1^* and S_2^* . S_2^* can also be calculated by using S_1^* and the private key of the hospital server.
 - It then computes $x^* = h(P_{NID_{Recd}} || TS_1^* || S_1^* || S_2^* || H_R^*)$ by using the above values. If the calculated value of x^* is equivalent to the received value of x , then the process of authentication between the Patient and the Hospital Server is successful otherwise the process will be terminated.
 - Random number n_2 is generated and timestamp TS_2 is recorded. ECC point multiplication is used to calculate $S_3 = n_2.P$.
 - G_1 and G_2 is computed and then it sends $G_1, G_2, TS_2, S_3, P_{NID}$ to the IoT device by public channel.
3. There is a need for mutual authentication between the Hospital Server and the IoT device. as the health data generated from the IoT devices is transferred to the

Hospital Server. There is the generation of a session key by the IoT device for secure communication between these two.

- Once the IoT device receives a message from the Hospital Server, it will first check $|TS_2^* - TS_2| \leq \Delta T$. If it satisfies then the process will continue otherwise it will be terminated.
 - It will then compute P_{TID}^* and G_2^* . If the calculated G_2^* is equivalent to the received G_2 , then there is successful authentication otherwise the process stops.
 - After successful authentication, it will generate a random number n_3 and record timestamp TS_3 . S_1^* can be calculated using received P_{NID} and P_{TID}^* .
 - ECC point multiplication is used to compute $S_4 = n_3 \cdot P$. Then, it will compute $D = S_3 + S_1^*$ by using ECC point addition.
 - After that session key is generated by computing $S_{Key_D} = h(S_1^* || S_3 || S_4) \oplus D$. This session key is used for secure communication.
 - It then computes G_3 and sends G_3, S_4, TS_3 to the Hospital Server by using public channel.
4. Hospital Server receives G_3, S_4, TS_3 and check the authenticity. It also generates session key S_{Key_HS} which is equivalent to the value of S_{Key_D} .
 - Firstly it verifies $|TS_3^* - TS_3| \leq \Delta T$ and the process will continue only if this condition is satisfied.
 - ECC point addition is used to find out HS using $S_3 = n_2 \cdot P$ and S_1^* which is calculated in the previous steps.
 - Using all the information, it calculates $S_{Key_HS} = h(S_1^* || S_3 || S_4) \oplus HS$ which is similar to S_{Key_D} .
 - It will compute G_3^* . If the calculated G_3^* is equivalent to the received G_3 , then there is successful authentication otherwise the process will be terminated.
 - Then, it records the current timestamp TS_4 and computes $HS_1 = h(P_{TID} || P_W) \oplus TS_4$
 - At last, it sends S_3, S_4, HS_1, TS_4 to the User through open channel.
 5. Once, the User receives S_3, S_4, HS_1 , and TS_4 , it will continue the further process of mutual authentication and key agreement.
 - The first step is to check $|TS_4^* - TS_4| \leq \Delta T$. If this condition is satisfied then only the process will continue otherwise it will stop.
 - It will then compute HS_1^* . If the calculated HS_1^* is equivalent to the received HS_1 , then there is successful authentication.
 - ECC point addition is used to compute P_3 and then session key S_{Key_P} is generated using $h(S_1 || S_3 || S_4) \oplus P_3$.
 - S_{Key_P} is equivalent to S_{Key_D} and S_{Key_HS} .

4.5 Password and biometric update phase

Patients are allowed to update their password and biometric input independently at regular times. This phase doesn't involve Hospital Servers and IoT Devices. The following steps are followed-

1. *Login with old credentials* Patient first enters its original identity P_{id} , old password P_{W_old} and biometric P_{Bio_old} . The next step is to verify the login credential of the patient as done previously. The following parameter is calculated.

$$Rep(P_{Bio_old}, P_{\tau_old}) = P_{\sigma_old}$$

$$R_{P_old} = P_1 \oplus h(P_{ID} || P_{W_old} || P_{\sigma_old})$$

$$P_{TPW_old} = h(P_{W_old} || P_{\sigma_old})$$

$$P_{NPW_old} = P_{TPW_old} \oplus R_{P_old}$$

If P_{NPW_old} is not equal to P_{NPW} , then the request for password update is declined. Otherwise, the password and biometric update request is accepted.

2. *Update credentials* Patient inputs new password P_{W_new} and imprint biometric P_{Bio_new} . Then the corresponding parameter is calculated as follows-

$$gen(P_{Bio_new}) = (P_{\sigma_new}, P_{\tau_new})$$

$$P_{1_new} = R_p \oplus h(P_{ID} || P_{W_new} || P_{\sigma_new})$$

$$R_p = P_{1_new} \oplus h(P_{ID} || P_{W_new} || P_{\sigma_new})$$

$$P_{TPW_new} = h(P_{W_new} || P_{\sigma_new})$$

$$P_{2_new} = H_R \oplus P_{TPW_new}$$

$$P_{NPW_new} = P_{TPW_new} \oplus R_{P_new}$$

Then, the old password P_{W_old} and P_{Bio_old} is replaced by the new P_{W_new} and P_{Bio_new} and stored value P_1, P_2, P_{NPW} in blockchain is updated by the new one.

4.6 User revocation phase

Any registered user or patient may be revoked from the use of the service once the subscription time is over. In that case, the user needs to regain its authority to use the service by performing the Re-Registration phase. The steps followed are-

1. *Login with old credentials* User enters its login credentials like P_{ID}, P_W, P_{Bio} . The corresponding parameter is calculated using these credentials as follows -

$$R_p = P_1 \oplus h(P_{ID} || P_W || P_{\sigma})$$

$$P_{TPW} = h(P_W || P_{\sigma})$$

$$P_{NPW} = P_{TPW} \oplus R_p$$

2. *Request for Re-Registration* On successful login, the request for re-registration is accepted and a random number R_{P_new} is generated. The corresponding parameters are calculated as follows-

$$P_{TID}^* = R_{P_new} \oplus P_{ID}$$

$$P_{TPW}^* = h(P_W || P_{\sigma})$$

$$P_{NPW}^* = P_{TPW}^* \oplus R_{P_new}$$

Then, sends P_{TID}^* and P_{NPW}^* as the re-registration request to the Hospital Server.

3. *Re-Registration Response* The remaining process will be the same as the registration phase.
4. *Replace stored value* The old, stored value like $P_1, P_2, P_{TID}, P_{NPW}$ is replaced with the new calculated value.

5 Security analysis and proofs

In our work, the security of the proposed scheme is proved by performing Formal as well as Informal Security Analysis. This shows that the proposed protocol is semantically correct and resistant to various attacks.

5.1 Formal security analysis using ROR model

The semantic security of the proposed schemes is proved by using one of the widely accepted ROR models. This model is used to justify the mutual authentication and key agreement scheme. Here, the network is controlled by the Adversary A . Adversary A have access to all the communication taking place between participants and A can use this by executing some queries to perform various types of security attacks. In this model, Adversary must be able to distinguish between an actual session key and a random secret key.

Participants There are three participants involved in the designed protocol- The patient, Hospital Server, and IoT Device. These participants or oracles are denoted by-

- $\delta_P^{a_1}$: Patient P having a_1 instance.
- $\delta_{HS}^{a_2}$: Hospital Server HS having a_2 instance.
- $\delta_D^{a_3}$: IoT Device D having a_3 instance.

Partnering Two instances of the participants being partners if both are in the accepted state, mutually authenticate each other, find the session key and are mutual partners.

Freshness Two instances are considered fresh when the adversary is unable to find the session key.

Adversary Adversary A has control over the network and can execute the given queries. These queries are used by A to perform various attacks. These are-

- $ED(\delta^{a_1}, \delta^{a_2})$: By using this query, A can get the message communicated between two participants. This leads to an eavesdropping attack.
- $SM(\delta^{a_1}, msg)$: This query is used by the adversary to send the message 'msg' in order to get some reply and thus perform an active attack on instance a_1 .
- $Corrupt_MD(\delta_P^{a_1})$: A use this query to get all the information stored in the patient's device.
- $TC(\delta^{a_1})$: After using this query, it returns the value 1 or 0 like the result of tossing an unbiased coin 'c'. The value of 'c' is 1 if it results in a sample of the secret key and is '0' if it results in an invalid symbol. Otherwise, it results in a null value.

Difference Lemma: For some probability distribution, assume that the events are denoted by A_1, A_2, A_3 .

Assumption: $B_1 \wedge \neg B_3 \iff B_2 \wedge \neg B_3$
 then, $|Pr[A_1] - Pr[A_2]| \leq Pr[A_3]$

Theorem 1 When adversary A is able to guess the communicating message, break the session key and authenticate the value of x, G_2, G_3, HS_1 successfully, there is a violation of the mutual authentication and key agreement protocol. This ability to break the protocol is denoted by $Adv^P(a)$. If the value of $Adv^P(a)$ is less valuable, then the proposed protocol is secure against the various security attack. This $Adv^P(a)$ should be -

$$Adv^P(a) \leq \frac{q_h^2}{|Hash|} + \frac{2 \cdot query_{send}}{2^m \cdot |D_{ID}| \cdot |D_{PW}|} + 2 \cdot Adv^{MAKAP}(a) \quad (2)$$

q_h = number of hash function

$|Hash|$ = hash function $h(\cdot)$ range space

$query_{send}$ = number of queries send

m = number of bits in P_{Bio}

$|D_{ID}|$ = total size of dictionary from which identity can be guessed

$|D_{PW}|$ = total size of dictionary from which password can be guessed

Proof Various scenario of Game denoted by Ga_i is defined. A tries to get the parameter like a random number, P_{ID}, P_W, P_{Bio} in order to break the security of the proposed mutual authentication and key agreement protocol. This can be done by correctly guessing the secret key or the authentication values and thus, winning the Game Ga_i in the given scenario. If the A fails to win the game, then it ensures that the proposed protocol provides secure mutual authentication and key agreement. $\square$

Let, S_i^A = This denote the success of A in the game Ga_i by guessing the correct bit 'c'.

$Pr[S_i^A]$ = This denote the probability of success of A by winning the game Ga_i .

$Adv^P(a)$ = This denote the advantage of A in destroying the security of session key.

$Adv^{MAKAP}(a)$ = this denotes the advantage of A in destroying the proposed protocol of mutual authentication and key agreement

A starts the game by Ga_0 and end with Ga_4 . These games are:

- Ga_0 : A performs real attack by guessing x, G_2, G_3, HS_1 at the start of Ga_0 . In Ga_0 , A doesn't perform any query and is unknown about the information related to the session key. Thus,

$$Adv^P(a) = |2Pr[S_0^A] - 1| \quad (3)$$

- Ga_1 : A execute the query $ED(\delta^{a_1}, \delta^{a_2})$ and eavesdrop the message communicated between the participants like (P_{NID}, x, TS_1) , (S_3, S_4, HS_1, TS_4) . Then A execute $TC(\delta^{a_1})$ in order to get the value of 'c'. By using the value of 'c', A knows if it is a session key or a random number. However, for getting session key $S_{Key_D} = h(S_1^* || S_3 || S_4) \oplus D$, A need S_1^* and so, P_{TID}, n_1, n_2, n_3 and it is not possible to know these parameter. Thus, the chances of winning Ga_1 by A are not increased by eavesdrop the message. So,

$$Pr[S_0^A] = Pr[S_1^A] \quad (4)$$

- Ga_2 : In Ga_2 , A attacks on participating entities by executing $SM(\delta^{a_1}, msg)$ and hash queries. They send an altered message and wait for the reply. For getting information of communicated message like (P_{NID}, x, TS_1) or (G_3, S_4, TS_3) , A need to know the secret key S_{Key_D} , random number like $n_1, n_2, n_3, R_p, R_D, R_{HS}^*$. These cannot be obtained as the protocol uses a one-way hash function which is collision resistance and there is no birthday attack. Hash values are unique and irreversible. By using a square approximation of the Birthday Paradox-

$$|Pr[S_1^A] - Pr[S_2^A]| \leq \frac{q_h^2}{2 \cdot |Hash|} \quad (5)$$

- Ga_3 : A try to get all the information stored in the Patient's device by executing $Corrupt_MD(\delta_p^{a_1})$. A corrupt patient's device and get stored information like P_1, P_2, P_{NPW} . As session key, $S_{Key_D} = h(S_1^* || S_3 || S_4) \oplus D$ involve use of S_1 which is not communicated by insecure channel and so, it needs to be derived by using received P_{NID} and stored P_{TID} . For getting P_{TID} , a random number R_p is required and it cannot be derived from the leaked information. R_p requires P_{ID}, P_W, P_{BIO} along with P_1 . A can only guess these parameters by attacking the dictionary of ID, Password, and Biometric of 'm' bits. Probability of guessing biometric of 'm' bits where $m \in (0, 1)^m$ is approximately $\frac{1}{2^m}$ and number of failed attempt made by A for guessing P_{ID}, P_W dictionary is $|D_{ID}| \& |D_{PW}|$. Then,

$$|Pr[S_3^A] - Pr[S_2^A]| \leq \frac{query_{send}}{2^m \cdot |D_{ID}| \cdot |D_{PW}|} \quad (6)$$

- Ga_4 : A can eavesdrop message like $(G_1, G_2, S_3, P_{NID}, TS_2)$ or (G_3, S_4, TS_3) or (HS_1, S_3, S_4, TS_4) and try to get session key $S_{Key_D} = h(S_1^* || S_3 || S_4) \oplus D$. For this, A require $S_1 = n_1.P, S_3 = n_2.P, S_4 = n_3.P$ which cannot be guessed as randomness and basepoint P of ECC based protocol is involved and so,

$$|Pr[S_4^A] - Pr[S_3^A]| \leq Adv^{MAKAP}(a) \quad (7)$$

After executing Ga_0 to Ga_4 , A executes $TC(\delta^{a_1})$ in order to get the value of 'c'. 'c' can be 1 or 0. Thus, the probability of success i.e. getting 1 is given by-

$$|Pr[S_4^A]| = \frac{1}{2} \quad (8)$$

Dividing eqs 3 by 2 on both sides,

$$\frac{Adv^P(a)}{2} = |2Pr[S_0^A] - \frac{1}{2}|$$

From eqs 4,

$$\frac{Adv^P(a)}{2} = |2Pr[S_1^A] - \frac{1}{2}| \quad (9)$$

By eqs 8,

$$\frac{Adv^P(a)}{2} = |2Pr[S_1^A] - Pr[S_4^A]|$$

Applying Difference Lemma,

$$\begin{aligned} |2Pr[S_1^A] - Pr[S_4^A]| &\leq |Pr[S_1^A] - Pr[S_2^A]| + |Pr[S_2^A] - Pr[S_4^A]| \\ &\leq |Pr[S_1^A] - Pr[S_2^A]| + |Pr[S_2^A] - Pr[S_3^A]| \\ &\quad + |Pr[S_3^A] - Pr[S_4^A]| \end{aligned} \quad (10)$$

Using eqs 5, 6, 7 :

$$\leq \frac{q_h^2}{2 \cdot |Hash|} + \frac{query_{send}}{2^m \cdot |D_{ID}| \cdot |D_{PW}|} + Adv^{MAKAP}(a)$$

From eqs 9, 10,

$$\begin{aligned} \frac{Adv^P(a)}{2} &\leq \frac{q_h^2}{2 \cdot |Hash|} + \frac{query_{send}}{2^m \cdot |D_{ID}| \cdot |D_{PW}|} + Adv^{MAKAP}(a) \\ Adv^P(a) &\leq \frac{q_h^2}{|Hash|} + \frac{2 \cdot query_{send}}{2^m \cdot |D_{ID}| \cdot |D_{PW}|} + 2 \cdot Adv^{MAKAP}(a) \end{aligned} \quad (11)$$

5.2 Formal security analysis using scyther

The proposed protocol is formally verified by using one of the widely accepted tools called Scyther. There is automated verification of security protocol with an unbound number of sessions and nonce [3]. This tool is based on the Dolev-Yao threat model where the adversary model is predefined and uses the Security Protocol Description Language (SPDL) [16]. The scyther tool is installed in the Windows operating system that prerequisites installation of Python 2.X, WxPython package, Graphviz, and Scyther Binaries. The written SPDL code is verified that display a simulation result window containing various security claims like secret, non-injective agreement(Niagree), non-injective synchronization(Nisynch), and the status of attacks. The proposed protocol of mutual authentication and key agreement phase consists of three participants- The user, Hospital Server, and IoT Device. Therefore,

three roles are written U, HS, and D having their own send, receive, match, and claim events as shown in Figs. 5 and 6. The simulation result of the proposed protocol shows that there is no attack as shown in Fig. 7. The summary of the carried out tests performed using the Scyther tool is explained as follows-

- *Secrecy*- By using this security claim, one can verify the confidentiality of certain values and assures that it is not exposed to the intruder. The proposed protocol satisfies the secrecy claim.
- *Alive*- In this security claim, one agent called initiator confirms the aliveness of another agent called responder. When the initiator completes the execution of the protocol and believes that the communicating responder is trustful, then the responder had been running the protocol before. This security claim is satisfied by the proposed protocol
- *Niagree*- This stands for a non-injective agreement which means that there is an agreement between two agents on the roles that each individual was assuming an agreement on certain data items utilized in the exchange. The result of the Scyther simulation justifies this security claim.
- *Nisynch*- This stands for non-injective synchronisation which means that all the sending and receiving events specified under various roles of the protocol are executed and are in order. The result shows that this claim is justified

```

1  hashfunction h;
2  function mult, add;
3  const xor: Function;
4  const cat: Function;
5  protocol bcecc(U, HS, D)
6  {
7    macro ptid=xor(rp, pid);
8    macro ptpw=h(cat(pw, psigma));
9    macro pnpw=xor(ptpw, rp);
10   macro p1=xor(rp, h(cat(pid, pw, psigma)));
11   macro p2=xor(hn, rp);
12   macro s1=mult(n1, p);
13   macro s2=mult(n1, pukhs);
14   macro p3=add(s3, s1);
15   macro sku=xor(h(cat(s1, s3, s4)), p3);
16   macro x'=h(cat(pnid', ts1', s1, s2, hr'));
17   macro x=h(cat(pnid, ts1, s1, s2, hr));
18   macro g1=xor(ptid, s3, ts2);
19   macro g2=xor(rd, rhs);
20   macro g2'=xor(rd, rhs');
21   macro
22     g3=xor(h(cat(rhs, rd, skd)), ts3, dnid);
23     macro
24       g3'=xor(h(cat(rhs', rd', skd)), ts3, dnid);
25     macro hs1=xor(h(cat(ptid, pw)), ts4);
26     macro hs1'=xor(h(cat(ptid, pw)), ts4);
27     macro hr=h(cat(ptid, prkhs));
28     macro hn=xor(hr, pnpw);
29     macro h1=xor(xor(did, rhs), rd);
30     macro ddnid=xor(rhs, did);
31     macro s3=mult(n2, p);
32     macro hs=add(s3, s1);
33     macro skhs=xor(h(cat(s1, s3, s4)), hs);
34     macro rhs'= xor(xor(h1, rd), did);
35     macro ddnid=xor(rhs', did);
36     macro rhs'= xor(xor(h1, rd), did);
37     macro ddnid=xor(rhs', did);
38     macro s4=mult(n3, p);
39     macro de=add(s3, s1);
40     macro skd=xor(h(cat(s1, s3, s4)), de);
41     role U
42     {
43       fresh
44         pid, pw, psigma, prho, rp, n1, s3, s4, ts1, p, puk
45         hs, prkhs, hr, pnid: Nonce;
46       var hr, ts4, rp, n3, n2;
47       fresh
48         ptid, ptpw, pnpw, p1, p2, s1, s2, p3, x, sku, hn, h
49         s1, ts1', pnid';
50       send_1(U, HS, {ptid, pnpw}pk(U));
51       recv_2(HS, U, {HS, hn}pk(U));
52       send_5(U, HS, {pnid, x, ts1}pk(U));
53       recv_8(HS, U, {s3, s4, ts4, hs1}pk(HS));
54       claim_n1(U, Secret, (sku));
55       claim_n2(U, Secret, (pnid));
56       claim_n3(U, Secret, (x));

```

Fig. 5 Sample SPDL code for the formal analysis

```

51  claim_n4(U, Alive);
52  claim_n5(U, Niagree);
53  claim_n6(U, Nisynch);
54  }
55  role HS
56  {
57  fresh
    prkhs, rhs, n2, ts2, p, skhs, ts4, pukhs, s4, rd',
    rhs', s3, hr', ts1', pnid' : Nonce;
58  var
    hr, did, rd, dnid, pnid, ts1, ts3, rp, psigma, pw
    , pid, skd, n1, n3;
59  fresh
    ptid, pnpw, hn, h1, x, s1, g1, g2, g3, hs1, hs, s2;
60  recv_1(U, HS, {ptid, pnpw}pk(U));
61  send_2(HS, U, {HS, hn}pk(U));
62  recv_3(D, HS, {did, rd}pk(D));
63  send_4(HS, D, {HS, h1}pk(D));
64  recv_5(U, HS, {pnid, x, ts1}pk(U));
65  match(x, x');
66  send_6(HS, D, {g1, g2, ts2, s3, pnid}pk(HS));
67  recv_7(D, HS, {s4, ts3, g3}pk(D));
68  match(g3, g3');
69  send_8(HS, U, {s3, s4, ts4, hs1}pk(HS));
70  claim_s1(HS, Secret, (skhs));
71  claim_s2(HS, Secret, (g2));
72  claim_s3(HS, Secret, (s3));
73  claim_s4(HS, Secret, (s4));

74  claim_s5(HS, Secret, (hs1));
75  claim_s6(HS, Alive);
76  claim_s7(HS, Niagree);
77  claim_s8(HS, Nisynch);
78  }
79  role D
80  {
81  fresh
    did, rd, n3, skd, ts3, n1, dnid, rhs, rhs' : Nonce
    ;
82  var ts2, s3, pnid, p, s3, n2, pid, rp;
83  fresh
    h1, g1, g2, s4, s1, de, g3, rd', ptid, pukhs;
84  send_3(D, HS, {did, rd}pk(D));
85  recv_4(HS, D, {HS, h1}pk(D));
86  recv_6(HS, D, {g1, g2, ts2, s3, pnid}pk(HS));
87  match(g2, g2');
88  send_7(D, HS, {s4, ts3, g3}pk(D));
89  claim_d1(D, Secret, (skd));
90  claim_d2(D, Secret, (g3));
91  claim_d3(D, Alive);
92  claim_d4(D, Niagree);
93  claim_d5(D, Nisynch);
94  }
95  }

```

Fig. 6 Sample SPDL code for the formal analysis

5.3 Informal security analysis

The formal analysis shows the semantic security of the session key. This section performs an informal analysis that shows that the proposed protocol satisfies the mutual authentication, derives a secure session key and resistant to various security attacks. This also explains the decrease in third party dependency by incorporating Blockchain that supports channel communication. Confidentiality among members is achieved by channel communication as the members belonging to the same channel can communicate securely and privately. The health data is stored in Blockchain which makes it immutable and prevents unauthorised access. Thus, the data shared is completely secured. The formal and informal analysis confirms that all the security goal is achieved. The description of analysis is given as-

1. *Mutual Authentication* By theorem 1, there is successful mutual authentication between the participants. A cannot calculate the value of x , G_2 , G_3 , HS_1 correctly as the value of $Adv^P(a)$ is less valuable.
2. *Session Key Agreement* Session Key derived by the participants are
 $S_{Key_D} = h(S_1^* || S_3 || S_4) \oplus D$, $S_{Key_HS} = h(S_1^* || S_3 || S_4) \oplus HS$, $S_{Key_P} = h(S_1 || S_3 || S_4) \oplus P_3$
 The value of

$$\begin{aligned}
 D &= S_3 + S_1^* = n_2.P + n_1.P \\
 HS &= S_3 + S_1^* = n_2.P + n_1.P \\
 P_3 &= S_3 + S_1 = n_2.P + n_1.P
 \end{aligned}$$

Scyther results : verify

Claim			Status	Comments	
bcecc	U	bcecc,n1	Secret xor(h(cat(mult(n1,p),s3,s4)),add(s3,mult(n1...	Ok	No attacks within bounds.
		bcecc,n2	Secret pnid	Ok	No attacks within bounds.
		bcecc,n3	Secret h(cat(pnid,ts1,mult(n1,p),mult(n1,pukhs),hr...	Ok	No attacks within bounds.
		bcecc,n4	Alive	Ok	No attacks within bounds.
		bcecc,n5	Niagree	Ok	No attacks within bounds.
		bcecc,n6	Nisynch	Ok	No attacks within bounds.
HS		bcecc,s1	Secret xor(h(cat(mult(n1,p),mult(n2,p),s4)),add(mu...	Ok	No attacks within bounds.
		bcecc,s2	Secret xor(rd,rhs)	Ok	No attacks within bounds.
		bcecc,s3	Secret mult(n2,p)	Ok	No attacks within bounds.
		bcecc,s4	Secret mult(n3,p)	Ok	No attacks within bounds.
		bcecc,s5	Secret xor(h(cat(xor(rp,pid),pw)),ts4)	Ok	No attacks within bounds.
		bcecc,s6	Alive	Ok	No attacks within bounds.
		bcecc,s7	Niagree	Ok	No attacks within bounds.
		bcecc,s8	Nisynch	Ok	No attacks within bounds.
D		bcecc,d1	Secret xor(h(cat(mult(n1,p),mult(n2,p),mult(n3,p))...	Ok	No attacks within bounds.
		bcecc,d2	Secret xor(h(cat(rhs,rd,skd)),ts3,dnid)	Ok	No attacks within bounds.
		bcecc,d3	Alive	Ok	No attacks within bounds.
		bcecc,d4	Niagree	Ok	No attacks within bounds.
		bcecc,d5	Nisynch	Ok	No attacks within bounds.

Done.

Fig. 7 Simulation result of the scyther tool

From above, it can be inferred that all the values are the same and so, $S_{Key_D} = S_{Key_HS} = S_{Key_P}$. Therefore, session key agreement is achieved by the proposed protocol.

3. *Reduced dependency on the third party* The participant Hospital Server is one of the nodes of the blockchain that stores the registration-related information in its local database and is secure, and immutable. There is no need for a trusted third party in order to store all this information. Thus, the dependence on third parties is reduced.

4. *Distributed database access an storage* The proposed scheme is implemented using Hyperledger Fabric. Hospital Server act as the Orderer Node of the blockchain network and various department like admin, reception, and so on act as the peer node. All the branches of the Hospital have their Hospital server and are a part of the Blockchain Network. The medical information stored in the database of one Hospital Server can be transferred to another Hospital Server by using the fabric's channel. Each node validates the transaction before execution. Hence, the proposed scheme provides distributed access and storage.
5. *Resistance against known session key attack* Session Key generated in the proposed protocol include S_1^*, D, HS, P or $S_{Key,D} = h(S_1^* || S_3 || S_4) \oplus D$. Even when the session key is known to A, it will not affect the security. This is because session key generation involves random numbers like n_1, n_2, n_3 which are different in every session and so, the session key is also different in every session. S_1^*, D, HS, P is not transferred through the insecure channel and so, A is not able to guess it correctly because of randomness in each session.
6. *Resistance against Replay Attack* The proposed scheme involves timestamp TS_1, TS_2, TS_3, TS_4 in the mutual authentication process. The difference between the receiving time of the message and the recorded time should be less than some threshold time value ΔT . Because ΔT is usually a very small value and so the attacker cannot replay the message in such a small time interval.
7. *Resistance against Man in the Middle attack*- Let the Adverasry A eavesdrop the message communicated like P_{NID}, x, TS_1 and try to change it. P_{NID} is computed using P_{TID}^* and S_1 . For getting the value of P_{TID}^* , A needs to compute $h(R_p^* || P_{ID}^*)$. The value of x can be obtained by using $h(P_{NID} || TS_1 || S_1 || S_2 || H_R^*)$. But the one-way hash function value cannot be the same and have collision resistance properties. So, A cannot get back the original value and are resistant to Man in the Middle Attack.
8. *Resistance against Impersonation attack* As the communicating message between the participants like $G_1, G_2, TS_2, S_3, P_{NID}$ involve XOR operation, hash() and random number. Hence, these parameter values cannot be detected by the A even when they try to impersonate.
9. *Forward Secrecy* Session key is derived by using $S_{Key,D} = h(S_1^* || S_3 || S_4) \oplus D$. For generating Session Key, A needs the value of S_1 and D . S_1 requires n_1 and P as $S_1 = n_1.P$ and D requires n_1, n_2 as $D = n_1.P + n_2.P$. This means A needs to find out the basepoint used in the ECC based protocol and solve the problem of ECC. This is not possible and so the proposed protocol provides forward secrecy.

6 Performance evaluation

This section involves the description of the blockchain based architecture of the cooperative hospital network. The comparative study of various features are shown in the Table 3. A consortium blockchain based system is designed using Hyperledger Fabric. It further includes the cost analysis of the proposed protocol for mutual authentication and key agreement. The computational, communication and storage cost is calculated

Table 3 Features comparison of various work related with authentication

Features	Tanveer et al. [35]	Dhar-minder et al. [8]	Xiang et al. [39]	Servati et al. [29]	Jiang et al. [15]	Sad-hukhan et al. [25]	Tan et al. [33]	Ours
Distributed immutable storage	×	×	✓	×	×	×	✓	✓
Consortium blockchain	×	×	✓	×	×	×	×	✓
Multiple Server Authentication	×	×	×	×	×	×	×	✓
No cryptocurrency	✓	✓	✓	✓	✓	✓	✓	✓
Support channel communication	×	×	✓	×	×	×	×	✓
Transfer information among server	×	×	×	×	×	×	×	✓
Reducing reliance on Trusted Third Party	×	×	✓	×	×	×	✓	✓
Withstand various security threat	✓	✓	✓	✓	✓	✓	✓	✓

and analyzed. Thenafter, the comparative cost analysis is discussed in Table 8 and in Table 9.

6.1 Experimental procedure

Hospital Consortium is designed using Hyperledger Fabric for secure medical information sharing. This section describes the tools used and the steps of implementation.

6.1.1 Tools used

Hyperledger Fabric is used that constitutes Cryptogen - version 2.1.1, Configtxgen-version 2.1.1, and RAFT consensus mechanism. ECC concept is used for key generation and authentication process. This work uses RoR Model for the Formal Analysis. The scyther tool is used for the simulation of the proposed protocol.

6.1.2 Hospital consortium implementation

There are various steps followed while designing the architecture of the Hospital Consortium.

- *Defining Node* The first step is setting up the basic network having only two organisations- Hospital Main Branch and an orderer organisation. This orderer organisation is managed by the Hospital's Main Branch. The second sub-branch is added as a member of the network in the next step. In the third step, the third sub-branch is added as an additional member, and so on. The number of Peer nodes increases in each step. For instance, the number of peer nodes is one after the first step, two after the second step, three after the third step, and so on. The hospital's Main Branch acts as an Orderer Node and the rest all the sub-branch act as Peer Nodes of the chain as shown in the figure.
- *Public Key Infrastructure* Hyperledger Fabric uses Public Key Infrastructure and the identity of each member is managed by Certification Authorities(CA). In the proposed work, each branch of the hospital has its own CA as shown in the figure to manage the identity of the members within it. `Crypto-config.yaml` file is created having all the information of the Hospital's Main Branch and its sub-branch and then public key certificates are created based on that information as shown in the figure.
- *Defining Genesis Block and creating channel* Genesis Block is the block from where the chain starts and it requires the information of Orderer Organisation. Hospital Genesis Block is created which is a binary file and so cannot be read. It needs to be converted into json file.

6.2 Computation cost analysis

The computational cost of the proposed protocol is analysed as shown in Table 5. The symbol hf denotes hash function, pm denotes ECC point multiplication, pa denotes point addition, fe denotes fuzzy extractor, bp denotes bilinear pairing and E/D denotes symmetric encryption decryption. Time taken for computation of various cryptographic operations is mentioned in Table 4. The computational time for the proposed protocol is calculated using this time as mentioned in various works [13, 40, 6]. The time taken for computation during the registration phase is $3hf$. The computational time for mutual authentication and key agreement process is $13hf$, $5pm$, $3pa$, $1fe$. The total computational time for the proposed protocol is $16hf$, $5pm$, $3pa$, $1fe$ which is equal to 0.12092 s.

6.3 Storage cost analysis

The storage cost of cryptographic operations like SHA-1 hash function, various identities, and password and nonce is 160 bits as shown in Table 6. Timestamp and Random Numbers take 32 bits. Storage cost of operations like symmetric encryption

Table 4 Computational time for various cryptographic operations

SYMBOL	MEANING	COMPUTATIONAL TIME (approx in second)
hf	Hash function	0.00032
pm	ECC point Multiplication	0.0171
pa	ECC point Addition	0.0044
fe	Fuzzy extractor	0.0171
E/D	Symmetric encryption Decryption	0.0056
bp	Bilinear pairing	0.0045

Table 5 Computational cost

Operation	Patient	Hospital Server	IoT Device	Total
PAT REG	$2hf$	$1hf$	–	$3hf$
IoT Dev REG	–		–	–
MA & KEYA	$6hf, 2pm, 1pa, 1fe$	$5hf, 2pm, 1pa$	$2hf, 1pm, 1pa$	$13hf, 5pm, 3pa, 1fe$
Total	$8hf, 2pm, 1pa, 1fe$	$6hf, 2pm, 1pa$	$2hf, 1pm, 1pa$	$16hf, 5pm, 3pa, 1fe$

Table 6 Storage cost of the proposed protocol

Operation	REG
Patient	480 bits
Hospital server	128 bits
IoT Device	96 bits
Total	704 bits

and decryption, ECC point, RSA encryption, and decryption is 128 bits, 320 bits, and 1024 bits respectively. During registration phase, Patient stores P_1, P_2, P_{NPW} that takes 480 bits ($160 + 160 + 160$). Hospital Server stores $P_{TID}, R_{HS}, D_{NID}, D_{ID}$ that takes 128 bits ($32+32+32+32$). IoT Device stores R_D, R_{HS}^*, D_{NID} that takes 96 bits ($32+32+32$). The total storage cost of the proposed protocol is 704 bits.

6.4 Communication cost analysis

Various messages are transmitted and received during the process of mutual authentication and key agreement. The cost of this communication is calculated in this section as shown in Table 7. The communication cost for various cryptographic

Table 7 Communication cost of the proposed system

Entity	Total number of messages transmitted	Communication cost
Patient	1	352 bits
Hospital Server	2	1536 bits
IoT Device	1	512 bits
Total	4	2400 bits

operations like SHA-1 hash function, ECC point, and Timestamp are 160, 320, and 32 bits respectively. Nonce takes 128 bits and RSA encryption decryption takes 1024 bits. The total number of the message communicated during the process of mutual authentication and key agreement is 4. Patient transmits one message P_{NID, x, TS_1} , and the communication cost for this is 352 (160+160+32)bits. Hospital Server transmits $G_1, G_2, TS_2, S_3, P_{NID}$ that takes 704 bits and HS_1, S_3, S_4, TS_4 that takes 832 bits. IoT Device sends S_4, TS_3, G_3 that takes 512 bits. The total communication cost for the transmission of four messages is 2400 bits.

7 Comparative cost analysis

The cost analysis of the proposed protocol and the existing one that uses the ECC protocol for mutual authentication and key agreement are compared in this section as shown in Figs. 8 and 9. This comparison is shown in Tables 8 and 9. All the related work studied for comparison includes user, entity 1 and entity 2 [14, 26, 6, 20]. The user can be a Patient or Doctor, Entity 1 can be a Server or Trusted Third Party, and Entity 2 can be a smart device or gateway. From Table 8 and considering Blockchain features, it has been concluded that the overall performance of the proposed protocol is better than the existing one. The cost of the Challa et al. [6] is

Table 8 Comparative computational cost analysis

PAPER	USER	ENTITY 1	ENTITY 2	TOTAL
Jia et al. [14]	6hf, 2pm, 1bp 0.04062 s	4hf, 2pm, 1bp 0.03998 s	11hf, 3pm, 1bp 0.05932 s	21hf, 7pm, 3bp 0.13992 s
Sahoo et al. [26]	9hf, 3pm, 1fe, 2E/D 0.08248 s	9hf, 2pm, 2E/D 0.04828 s	3hf, 2pm, 2E/D 0.04636 s	21hf, 7pm, 1fe, 6E/D 0.17712 s
Ma et al. [20]	4hf, 3pm 0.05258 s	4hf, 4pm 0.06968 s	11hf, 10pm 0.17452 s	19hf, 17pm 0.29678 s
Challa et al. [6]	13hf, 2pm, 1fe 0.05546	4hf, 1pm 0.01838 s	4hf 0.00128 s	21hf, 3pm, 1fe 0.07512 s
Proposed	8hf, 2pm, 1pa, 1fe 0.05826 s	6hf, 2pm, 1pa 0.04052 s	2hf, 1pm, 1pa 0.02214 s	16hf, 5pm, 3pa, 1fe 0.12092 s

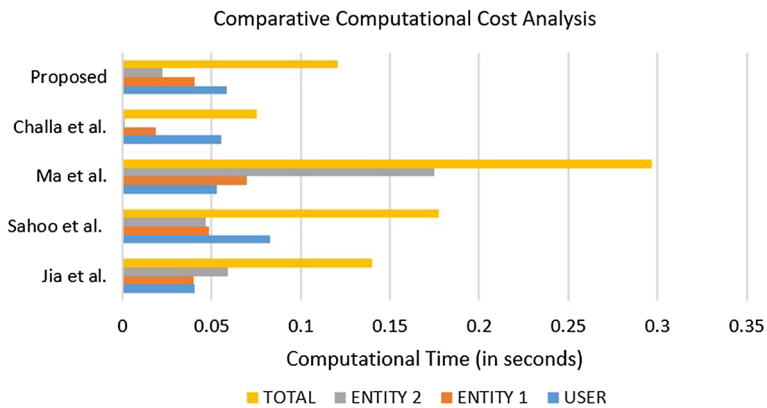


Fig. 8 Comparative computational cost analysis of the proposed system

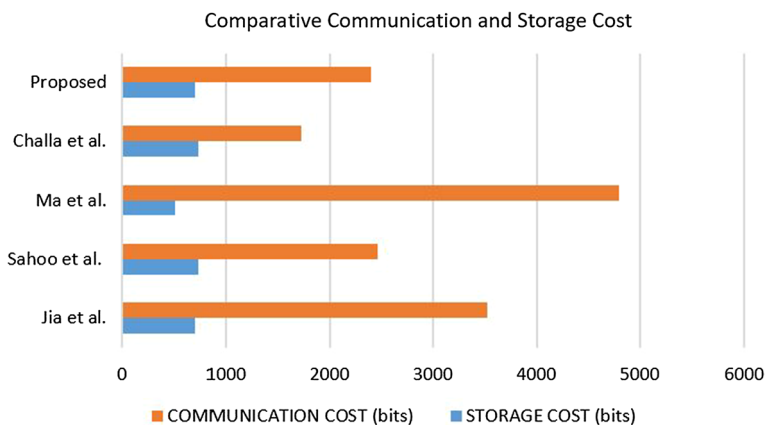


Fig. 9 Comparative communication and storage cost analysis of the proposed system

Table 9 Comparative communicational and storage cost analysis

PAPER	Storage COST (bits)	Communication COST (bits)
Jia et al. [14]	704	3520
Sahoo et al. [26]	736	2464
Ma et al. [20]	512	4800
Challa et al. [6]	736	1728
Proposed	704	2400

slightly lower than the proposed protocol but it involves trusted authority that can be compromised. This work heavily relies on the trusted third party and centralised way of data storage. This leads to single-point failure, computational overhead and

an increase in latency. To solve this issue, the proposed protocol involves a Blockchain concept where there are multiple hospital server that is a part of the Blockchain. This decreases the dependency on the third party and makes the stored data immutable. The storage cost of Ma et al. [20] is 192 bits lesser than the proposed protocol but the communication cost is 2400 bits larger than the proposed protocol. The computational time taken by this protocol is also larger than the proposed protocol. It also lacks a multiple-server concept in order to decrease computational overhead at a single server. Moreover, this work doesn't have a Blockchain concept. The proposed work consists of a Blockchain concept that supports channel communication. This increases the confidentiality among members belonging to the same channel. Thus, the privacy and security of health data are enhanced by incorporating the Blockchain concept in the proposed protocol. Considering all these points, the proposed protocol is more effective and more secure than the existing work. The use of the Blockchain concept makes it more secure, immutable, and decentralised.

8 Conclusion

This COVID-19 pandemic increases the demand for secure health data sharing so that it can be used by multiple hospitals and users irrespective of their location. So, the health data should be collected only from the authentic IoT device and shared with authentic users. The dependency on a single trusted third party and centralised server leads to various problems like single point failure, lack of confidentiality among members, mutable storage, and increase in latency and computation at centralised server. This problem can be solved by incorporating the Blockchain concept. The proposed work provides the mutual authentication and key agreement scheme between IoT devices and Hospital servers, between Users(Patient or Doctor) and Hospital servers. The registration related information is stored in the Blockchain. Different branches of the hospital can communicate with each other using the channel.

So, integrating the Consortium Blockchain concept for storing information makes the system distributed and immutable. This is implemented using the Hyperledger Fabric platform that supports channel communication. Communication using the channel increases confidentiality among the participating members. The information on the transaction is known only to the members connecting with that channel. Moreover, multiple-server concept decreases the computational overload a centralised server. ECC-based authentication and key agreement protocol increase the security level with smaller key sizes and fast key generation. The formal, informal analysis and comparative study show that the proposed work is more secure and effective than the existing scheme.

In the future, the intended project will expand to include the development of an authentication scheme designed for Distributed Applications (DApps) and conducting real-time analysis. To assess the viability of the DApp, the analysis will utilize platforms such as Hyperledger Fabric, Hyperledger Caliper, and Polygon.

Author contributions Conceptualization: [Divya Rani]; Methodology: [Divya Rani]; Formal analysis and investigation: [Divya Rani]; Writing-original draft preparation: [Divya Rani]; Writing-review and editing: [Sachin Tripathi]; Supervision: [Sachin Tripathi].

Funding This declaration is “not applicable”.

Data availability This declaration is “not applicable”.

Declarations

Conflict of interest On behalf of all authors, the corresponding authors declare that they have no known competing interests that are directly or indirectly related to the work submitted for publication.

Ethical Approval This declaration is “not applicable”.

References

1. Aggarwal S, Kumar N (2021) Hyperledger. In: Advances in computers, vol. 121, pp. 323–343. Elsevier
2. Alyahya S, Khan WU, Ahmed S, Marwat SNK, Habib S (2022) Cyber secure framework for smart agriculture: Robust and tamper-resistant authentication scheme for iot devices. *Electronics* 11(6):963
3. Amin R, Lohani P, Ekka M, Chourasia S, Vollala S (2020) An enhanced anonymity resilience security protocol for vehicular ad-hoc network with Scyther simulation. *Comput Electric Eng* 82:106554
4. Androulaki E, Barger A, Bortnikov V, Cachin C, Christidis K, De Caro A, Enyeart D, Ferris C, Laventman G, Manevich Y, et al (2018) Hyperledger fabric: a distributed operating system for permissioned blockchains. In: Proceedings of the thirteenth EuroSys conference, pp. 1–15
5. Anuradha M, Jayasankar T, Prakash N, Sikkandar MY, Hemalakshmi G, Bharatiraja C, Britto ASF (2021) Iot enabled cancer prediction system to enhance the authentication and security using cloud computing. *Microprocess Microsyst* 80:103301
6. Challa S, Das AK, Odelu V, Kumar N, Kumari S, Khan MK, Vasilakos AV (2018) An efficient ECC-based provably secure three-factor user authentication and key agreement protocol for wireless healthcare sensor networks. *Comput Electric Eng* 69:534–554
7. Cheng X, Chen F, Xie D, Sun H, Huang C, Qi Z (2019) Blockchain-based secure authentication scheme for medical data sharing. In: Data Science: 5th International Conference of Pioneering Computer Scientists, Engineers and Educators, ICPCSEE 2019, Guilin, China, September 20–23, 2019, Proceedings, Part I, pp. 396–411. Springer
8. Dharminder D, Mishra D, Li X (2020) Construction of RSA-based authentication scheme in authorized access to healthcare services: authorized access to healthcare services. *J Med Syst* 44:1–9
9. Du M, Chen Q, Chen J, Ma X (2020) An optimized consortium blockchain for medical information sharing. *IEEE Trans Eng Manag* 68(6):1677–1689
10. Fan K, Zhu S, Zhang K, Li H, Yang Y (2019) A lightweight authentication scheme for cloud-based RFID healthcare systems. *IEEE Netw* 33(2):44–49
11. Hamidi H (2019) An approach to develop the smart health using internet of things and authentication based on biometric technology. *Future Gener Comput Syst* 91:434–449
12. Hathaliya JJ, Tanwar S, Tyagi S, Kumar N (2019) Securing electronics healthcare records in healthcare 4.0: A biometric-based approach. *Comput Electric Eng* 76:398–410
13. He D, Kumar N, Lee JH, Sherratt RS (2014) Enhanced three-factor security protocol for consumer USB mass storage devices. *IEEE Trans Consum Electron* 60(1):30–37
14. Jia X, He D, Kumar N, Choo KKR (2019) Authenticated key agreement scheme for fog-driven IOT healthcare system. *Wireless Networks* 25(8):4737–4750
15. Jiang Q, Zhang N, Ni J, Ma X, Choo KKR (2020) Unified biometric privacy preserving three-factor authentication and key agreement for cloud-assisted autonomous vehicles. *IEEE Trans Veh Technol* 69(9):9390–9401
16. Khadem B, Suteh AM, Ahmad M, Alkhayyat A, Farash MS, Khalifa HS (2021) An improved WBSN key-agreement protocol based on static parameters and hash functions. *IEEE Access* 9:78463–78473
17. Khan WU, Marwat SNK, Ahmed S (2022) Cyber secure framework for smart containers based on novel hybrid DTLS protocol. *Comput Syst Sci Eng* 43(3)

18. Lashkari B, Musilek P (2021) A comprehensive review of blockchain consensus mechanisms. *IEEE Access* 9:43620–43652
19. Lei CL, Chuang YH (2019) Privacy protection for telecare medicine information systems with multiple servers using a biometric-based authenticated key agreement scheme. *IEEE Access* 7:186480–186490
20. Ma M, He D, Wang H, Kumar N, Choo KKR (2019) An efficient and provably secure authenticated key agreement protocol for fog-based vehicular ad-hoc networks. *IEEE Internet Things J* 6(5):8065–8075
21. Madhusudhan R, Nayak CS (2019) A robust authentication scheme for telecare medical information systems. *Multimed Tools Appl* 78:15255–15273
22. Masud M, Gaba GS, Choudhary K, Hossain MS, Alhamid MF, Muhammad G (2021) Lightweight and anonymity-preserving user authentication scheme for iot-based healthcare. *IEEE Internet Things J* 9(4):2649–2656
23. Miller A (2019) Permissioned and permissionless blockchains. *Blockchain for distributed systems security* pp. 193–204
24. Rehman ZU, Altaf S, Iqbal S (2020) An efficient lightweight key agreement and authentication scheme for WBAN. *IEEE Access* 8:175385–175397
25. Sadhukhan D, Ray S, Biswas G, Khan MK, Dasgupta M (2021) A lightweight remote user authentication scheme for IOT communication using elliptic curve cryptography. *J Supercomput* 77:1114–1151
26. Sahoo SS, Mohanty S, Majhi B (2021) A secure three factor based authentication scheme for health care systems using IOT enabled devices. *J Ambient Intell Humaniz Comput* 12(1):1419–1434
27. Sarwar A, Alnajim AM, Marwat SNK, Ahmed S, Alyahya S, Khan WU (2022) Enhanced anomaly detection system for IOT based on improved dynamic SBPSO. *Sensors* 22(13):4926
28. Sarwar A, Hasan S, Khan WU, Ahmed S, Marwat SNK (2022) Design of an advance intrusion detection system for IOT networks. In: 2022 2nd international conference on artificial intelligence (ICAI), pp. 46–51. *IEEE*
29. Servati MR, Safkhani M (2023) ECCBAS: an ECC based authentication scheme for healthcare IOT systems. *Pervasive Mob Comput* 90:101753
30. Soni M, Singh DK (2021) Privacy-preserving authentication and key-management protocol for health information systems. In: *Data Protection and Privacy in Healthcare*, pp. 37–50. *CRC Press*
31. Sowjanya K, Dasgupta M, Ray S (2021) Elliptic curve cryptography based authentication scheme for internet of medical things. *J Inf Secur Appl* 58:102761
32. Swan M (2015) *Blockchain: Blueprint for a new economy*. “O’Reilly Media, Inc.”
33. Tan TL, Salam I, Singh M (2022) Blockchain-based healthcare management system with two-side verifiability. *Plos one* 17(4):e0266916
34. Tang F, Ma S, Xiang Y, Lin C (2019) An efficient authentication scheme for blockchain-based electronic health records. *IEEE Access* 7:41678–41689
35. Tanveer M, Alkhayyat A, Chaudhry SA, Zikria YB, Kim SW et al (2022) Reas-tmis: resource-efficient authentication scheme for telecare medical information system. *IEEE Access* 10:23008–23021
36. Wang P, Li B, Shi H, Shen Y, Wang D (2019) Revisiting anonymous two-factor authentication schemes for iot-enabled devices in cloud computing environments. *Security and Communication Networks* **2019**
37. Wang W, Hoang DT, Hu P, Xiong Z, Niyato D, Wang P, Wen Y, Kim DI (2019) A survey on consensus mechanisms and mining strategy management in blockchain networks. *Ieee Access* 7:22328–22370
38. Wood G et al (2014) *Ethereum: a secure decentralised generalised transaction ledger*. *Ethereum Project Yellow Paper* 151(2014):1–32
39. Xiang X, Wang M, Fan W (2020) A permissioned blockchain-based identity management and user authentication scheme for e-health systems. *IEEE Access* 8:171771–171783
40. Zhao X, Li D, Li H (2022) Practical three-factor authentication protocol based on elliptic curve cryptography for industrial internet of things. *Sensors* 22(19):7510

Publisher's Note Springer Nature remains neutral with regard to jurisdictional claims in published maps and institutional affiliations.

Springer Nature or its licensor (e.g. a society or other partner) holds exclusive rights to this article under a publishing agreement with the author(s) or other rightsholder(s); author self-archiving of the accepted manuscript version of this article is solely governed by the terms of such publishing agreement and applicable law.

Authors and Affiliations

Divya Rani¹ · Sachin Tripathi¹

✉ Divya Rani
divyarani.1235@gmail.com

¹ Department of Computer Science and Engineering, Indian Institute of Technology (Indian School of Mines), Dhanbad, India